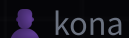


SupplyGuard

AI 编程时代的多 Agent 供应链安全守门员

从 PR 拦截到零日响应，让依赖安全从"告警"走向"闭环"



kona



供应链安全



多 Agent 协同

AI 写代码会"幻觉"出根本不存在的包名，
攻击者抢注这些名字就能让恶意代码随 PR 入库。

✗ 传统 SCA 工具

- 只扫描、只告警
- 不参与决策
- 零日爆发后靠人肉救火

✓ SupplyGuard

- 检测 → 分析 → 决策 → 修复 → 验证 → 审计
- 4 个 Agent 闭环协同
- 自动拦截与自动修复

AI 编程时代，依赖安全出现新攻击面

传统工具设计于"人类写代码"时代，对 LLM 生成内容缺乏原生防御



AI 幻觉包名

Copilot / Cursor / Claude Code 可能生成不存在的包名，攻击者抢注后形成 slopsquatting 攻击。



告警即终点

Snyk、Dependabot 只告诉你"有风险"，修不修、怎么修仍然依赖人工判断。



零日响应慢

xz-utils、event-stream 等事件爆发后，团队需要数小时甚至数天才能完成影响面评估与修复。



中小团队缺方案

缺乏轻量、可自托管、能闭环修复的智能供应链安全方案



元级风险：Agent 自身可能被攻击

恶意包的 README、CVE 描述里可能嵌入 prompt injection，操纵 Agent 帮它"过关"——这是传统 OSS 工具无法解决的，但 AI 时代产品必须原生的防御

双入口 · 一引擎 · 全闭环

两个风险时刻共享同一套底层能力，实现从"引入"到"爆发"的全覆盖



4 个 Agent，职责最小化，决策与执行分离



AnalysisRequest

RiskProfile

RemediationOrder

Verdict

状态机: received → analyzing → arbitrating → remediating → verifying → sealed

七层洋葱式安全架构

恶意包内容可能反过来攻击 Agent 自身——这是 Agent 化供应链安全产品独有的元级风险

1 感知层

所有外部输入统一标记 UNTRUSTED

2 净化层

沙箱解析、注入检测、异常编码剥离

3 上下文隔离

untrusted_source 边界标签、spotlighting

4 能力最小化

每个 Agent 只拥有职能所需最小工具集

5 决策仲裁

Auditor 只看结构化证据链，不接触原文

6 执行沙箱

install / test 全隔离，--ignore-scripts

7 审计不可否认

Provenance 签名、append-only log、证据哈希

⚠️ 核心洞察

这是 SupplyGuard 相对 Snyk / Dependabot 的结构性差异——存量工具不是 LLM 系统，无需担心 prompt injection。

13 个可复用 Skill，分层解耦

每个 Skill 定义输入输出 Schema、调用条件、失败处理、安全边界与复用价值

数据层

`sbom-build` 解析 lockfile，构建依赖图与 SBOM 快照

信号层

`cve-match` `hallucination-check` `maintainer-profile` `license-check`

融合层

`risk-profile` 多信号融合，输出可审计的 RiskProfile

修复层

`bump-version` `swap-dependency` `quarantine-package` `patch-gen`

验证层

`sandbox-test-run` `reachability-scan`

治理层

`policy-check` `evidence-verify` `audit-log-write` `human-approval-request`

AI 时代独有能力

`hallucination-check` 识别 LLM 幻觉包与 slopsquatting 攻击，是 SupplyGuard 最具差异化的 Skill。

失败可降级

每个 Skill 定义默认降级行为：重试 / 保守假设 / 转人工 / 阻断，确保单点故障不会导致系统失控。

AgentTeams / HiClaw 原生适配

Sentinel = Manager Agent · Analyst / Remediator / Auditor = Worker Agents

SupplyGuard	HiClaw 角色	核心职责
Sentinel	Manager Agent	事件路由、任务拆分、状态机推进
Analyst	Worker Agent	只读分析，输出 RiskProfile
Remediator	Worker Agent	修复策略落地，开 PR
Auditor	Worker（仲裁特 权）	终局裁决、审计留痕
安全负责人	Human	Matrix room 实时审批

编排舞台：Matrix Room

- 所有 Agent 在 room 中 @ 彼此协作
- 消息历史天然可审计、可回放
- Human 可随时介入审批
- OpenTelemetry Trace 覆盖每次调用

Agent Identity = system prompt + MCP binding + RBAC + pod template

name role permissions tools

初赛可运行，复赛可扩展

层级	v1（初赛）	复赛 / 生产
多 Agent 框架	本地 LocalOrchestrator	AgentTeams / HiClaw
数据层	SQLite + pgvector	PolarDB for PostgreSQL
消息队列	内存队列	RocketMQ
配置治理	本地 YAML	Nacos
AI 网关	直接调用	Higress
可观测	stdout / Jaeger	AgentLoop / LoongSuite
MCP 工具	GitHub、npm registry、OSV、CI Trigger、Approval Gateway	

v1 先用最小可运行栈跑通端到端；复赛阶段迁移到推荐云产品，展示架构可替换性。

AI 幻觉包拦截：从 PR 到 Block 裁决

```
// AI 生成的代码片段  
import { cloneDeep } from 'lodos';
```



Analyst
发现
registry
中不存在
lodos



Auditor
仲裁
Verdict =
Block



Remediator
自动写阻
止
comment

VERDICT: BLOCK

RiskLevel: critical • Action: wrote_blocking_comment •
AuditSeal: sealed

实际运行证据

- 已跑通 slopsquatting 拦截 Demo
- 自动识别 `lodos` 等 typosquat 包
- 输出 block 裁决与审计日志
- CVE 响应 Demo 剧本已设计

运行入口

```
uv run python -m  
supplyguard.demo.scan_repository  
./my-app
```

可复用、可开源、可商业化

开放 / 复用价值

- Skill 层是独立任务能力抽象，可被守门 / 响应两模式共享
- Agent Identity 与 MCP 接入契约结构化，可迁移至任意多 Agent 框架
- SBOM、包画像、修复策略可被外部 Agent 系统复用
- v1 先完整产品验证，成功后考虑独立 SDK 开源

目标客户

- 中小技术团队 / AI 原生创业公司
- 对供应链安全有强需求的企业
- 需要自托管、可审计安全方案的组织

商业化路径

Phase 1

完整闭源产品，验证付费意愿

Phase 3

商业化成功后输出独立 SDK / 开源基础设施

Phase 2

Skill 设计、Agent Identity、injection detector 逐步开源

从方案设计到完整端到端演示

8.16 初赛

方案设计 + 可运行 Demo

4 Agent 分工、13 Skill 清单、洋葱安全架构、slopsquatting 拦截 Demo

9.3 复赛

AgentTeams 真实接入 + 云产品集成

HiClaw 跑通、PolarDB、RocketMQ、AgentLoop/LoongSuite、CVE 响应 Demo

9.22 决赛

现场路演 + 完整端到端演示

真实仓库 PR 拦截、零日 CVE 自动修复、人工审批闭环



方案设计完成



骨架代码可运行



Demo 已跑通



HiClaw 接入验证中

SupplyGuard

让 AI 编程时代的依赖安全，从"告警"走向"闭环"

4 Agents

13 Skills

7 层洋葱安全

双入口闭环

Thank You · Q&A